



Bundesamt
für Sicherheit in der
Informationstechnik

Deutschland
Digital•Sicher•BSI•

Technische Richtlinie TR-03174: Anforderungen an Anwendungen im Finanzwesen

Teil 3: Hintergrundsysteme
Version 4.0



Änderungshistorie

<i>Version</i>	<i>Datum</i>	<i>Name</i>	<i>Beschreibung</i>
1.0	18.05.2022	Referat DI 24	Erste Version
2.0	25.03.2024	Referat DI 24	Überarbeitung Kapitel 3 Überarbeitung Kapitel 4
3.0	16.09.2024	Referat D24	Finalisierung
4.0	01.06.2026	Referat D24	Ganzheitliche Überarbeitung der TR, Inhalt und Struktur

Inhalt

1	Einleitung.....	5
1.1	Gegenstand der Technischen Richtlinie.....	5
1.2	Übersicht der Technischen Richtlinie	5
1.2.1	Aufbau.....	5
1.2.2	Begriffe	5
2	Überblick der Anwendungen im Finanzwesen.....	6
2.1	Anwendungskonzepte auf mobilen Endgeräten (TR-03174, Teil 1)	6
2.1.1	Native-Applikationen.....	6
2.1.2	Hybride Ansätze.....	6
2.2	Web-Anwendungen (TR-03174, Teil 2).....	6
2.3	Hintergrundsysteme (TR-03174, Teil 3, dieses Dokument).....	7
2.3.1	Selbst gehostete Systeme	7
2.3.2	Cloud Computing.....	7
3	Security Problem Definition	8
3.1.1	Annahmen	8
3.1.2	Bedrohungen	8
3.1.3	Organisatorische Sicherheitspolitiken	8
3.1.4	Restrisiken.....	9
4	Prüfaspekte für Anwendungen im Finanzwesen	11
4.1	Anwendungszweck.....	11
4.2	Architektur.....	11
4.3	Quellcode.....	12
4.4	Drittanbieter-Software	13
4.5	Kryptographische Umsetzung.....	14
4.6	Authentisierung und Authentifizierung	14
4.7	Datensicherheit.....	15
4.8	Netzwerkkommunikation.....	16
4.9	Organisatorische Sicherheit.....	17
	Abkürzungsverzeichnis.....	23
	Literaturverzeichnis	25

Tabellenverzeichnis

Tabelle 1: Begriffe der Technischen Richtlinie.....	5
Tabelle 2 Anwendungszweck.....	11
Tabelle 3 Architektur.....	11
Tabelle 4 Quellcode.....	12
Tabelle 5 Drittanbieter-Software	13
Tabelle 6 Kryptographische Umsetzung.....	14
Tabelle 7 Authentisierung und Authentifizierung	14
Tabelle 8 Datensicherheit.....	15
Tabelle 9 Netzwerkkommunikation.....	16
Tabelle 10 Organisatorische Sicherheit	17
Tabelle 11: Prüftiefen und Mindestanforderungen.....	18
Tabelle 12: Mögliche Prüfergebnisse	19
Tabelle 13: Anforderung anhand der Daten-Kritikalität.....	20
Tabelle 14: Schutzbedarf sensibler Datenelemente.....	21
Tabelle 15: Abkürzungsverzeichnis.....	23

1 Einleitung

1.1 Gegenstand der Technischen Richtlinie

Das Bundesamt für Sicherheit in der Informationstechnik [BSI] verfügt mit den IT-Grundsatzbausteinen und diversen Technischen Richtlinien [TR] über Umsetzungshilfen, um Anwendungen und IT-Infrastrukturen nach dem Stand der Technik abzusichern. Die vorliegende TR soll bei der Erstellung und dem Betrieb von Hintergrundsystemen im Finanzumfeld mit einer kompakten Übersicht möglicher technischer Maßnahmen zur Informationssicherheit unterstützen. Die TR richtet sich vor allem an einen nicht regulierten, heterogenen Adressatenkreis von Entwicklern und Anbietern mobiler Anwendungen, Web-Anwendungen und deren Hintergrundsysteme im finanznahen Umfeld, beispielsweise digitale Haushalts- und Kassenbücher, Steuer-, Finanz- und Kreditrechner sowie Apps mit Bezahlfunktion von Discounter.

Die Hinweise und Empfehlungen der TR stellen keine regulatorischen Pflichten dar. Für Finanzunternehmen, die einer Regulierung unterliegen, kann diese TR als eine Orientierungshilfe bei der Umsetzung der regulatorischen Vorgaben dienen. Europäische (z.B. [PSD2], [DORA], etc.) und / oder nationale Vorgaben (z.B. Rundschreiben der Bundesanstalt für Finanzdienstleistungsaufsicht [BaFin]) haben Vorrang vor den Empfehlungen der TR. Die alleinige Umsetzung der TR entbindet daher nicht von der zusätzlichen, weiterführenden Auseinandersetzung mit regulatorischen und weiteren technischen Vorgaben.

1.2 Übersicht der Technischen Richtlinie

1.2.1 Aufbau

Hintergrundsysteme im Sinne dieser TR sind IT-Infrastrukturen, welche den Betrieb von Web-Anwendungen und Applikationen auf mobilen Endgeräten gewährleisten (Definition in Kapitel 2). Kapitel 3 zeigt Annahmen, Bedrohungen und organisatorische Sicherheitspolitiken auf, welche als Hintergrundinformation für die weitere Anwendung der TR dienen. In Kapitel 4 werden die Empfehlungen an die Hintergrundsysteme aufgelistet, Kapitel 5 zeigt das Vorgehen der Auditierung der Umsetzung dieser Empfehlungen auf. Anhang A gibt Beispiele für den Schutzbedarf, welcher zur Risikobewertung existenziell ist. Die Tabellen der Anlage B können bei der Auditierung genutzt werden.

1.2.2 Begriffe

Diese Technische Richtlinie verwendet folgende Begriffe:

Tabelle 1: Begriffe der Technischen Richtlinie

Begriff	Beschreibung
MUSS	Der Hersteller muss eine bestimmte Eigenschaft zwingend implementieren.
DARF NICHT / DARF KEIN(E)	Das Hintergrundsystem darf eine bestimmte Eigenschaft unter keinen Umständen aufweisen.
SOLL	Das Hintergrundsystem muss eine bestimmte Eigenschaft aufweisen, außer es wird dargelegt, dass durch ein Nicht-Umsetzen kein Risiko für den sicheren Betrieb besteht, bzw. eine Umsetzung, aufgrund von technischen Einschränkungen, derzeit nicht möglich ist.
KANN	Das Hintergrundsystem kann eine bestimmte Eigenschaft aufweisen, wobei ein Umsetzen dieser Eigenschaft vom Lösungsanbieter anzuzeigen ist.

2 Überblick der Anwendungen im Finanzwesen

2.1 Anwendungskonzepte auf mobilen Endgeräten (TR-03174, Teil 1)

Der Begriff „mobile Anwendung“ bezeichnet ein Programm, das auf einer mobilen Plattform ausgeführt wird. Grundsätzlich lassen sich solche Anwendungen in drei Kategorien unterteilen:

1. Native Anwendungen, zugeschnitten auf die Plattform, auf der sie ausgeführt werden,
2. Web-Anwendungen, plattformunabhängige Implementierung, laufen im Web-Browsers,
3. Hybride Ansätze, Kombinationen aus nativen Anwendungen und Web-Anwendungen.

Da mobile Anwendungen weit über den Einsatz von Web-Anwendungen in mobilen Browsern oder hybriden Anwendungen hinausgehen, liegt der Fokus dieser TR auf nativen Anwendungen und dem nativen Teil von hybriden Ansätzen.

2.1.1 Native-Applikationen

Eine native Anwendung ist passend auf eine Plattform und deren Betriebssystem (beispielsweise Android oder [iOS]) zugeschnitten. Sie basiert auf den bereitgestellten Programmierwerkzeugen (Software Development Kits [SDK]). Diese ermöglichen einen direkten Zugriff auf Gerätekomponenten, wie beispielsweise [GPS], Kamera oder Mikrofon. Aufgrund ihrer Nähe zum Betriebssystem können sie eine gute Performanz, hohe Zuverlässigkeit und intuitive Bedienbarkeit erreichen. Die Anwendungen werden beispielsweise über den plattformeigenen [App]-Store installiert und können oft auch offline betrieben werden. Die Nähe zum Betriebssystem ist auch mit Nachteilen verbunden. Änderungen am Betriebssystem, beispielsweise durch Updates, können dazu führen, dass Anpassungen an der Anwendung vorgenommen werden müssen. Darüber hinaus ist es nicht möglich sie auf anderen Betriebssystemen zu installieren.

2.1.2 Hybride Ansätze

Hybride Anwendungen verbinden sowohl die Vor-, als auch die Nachteile von nativen Anwendungen und Web-Anwendungen. Mit Hilfe des SDKs wird eine Art „Rahmen-Anwendung“ geschaffen. Sie kann auf Gerätekomponenten zugreifen und über einen App-Store bezogen, jedoch nicht auf anderen Plattformen installiert werden, ohne Anpassungen am Quellcode vorzunehmen. Darüber hinaus beinhalten die Rahmen-Anwendungen einen eingebetteten Web-Browser, mit dessen Hilfe Web-Anwendungen in native Anwendungen eingebunden werden können. Dadurch ist es auch Web-Anwendungen möglich, auf die sonst nur den nativen Anwendungen vorbehaltenen Gerätekomponenten zuzugreifen. Allerdings müssen dabei Einbußen bei der Performanz und Stabilität in Kauf genommen werden.

2.2 Web-Anwendungen (TR-03174, Teil 2)

Web-Anwendungen sind Anwendungsprogramme, meist Webseiten, die in Kombination mit einem Hintergrundsystem (Kapitel 2.3) ohne Installation auf einem lokalen System betrieben werden können. Solche Webseiten sind oft so programmiert, dass sie wie eine native Anwendung für klassische Desktop-Systeme oder mobile Endgeräte aussehen und sich vergleichbar verhalten. Im Gegensatz zu nativen Anwendungen basieren sie nicht auf einem SDK der zugrundeliegenden Plattformen, sondern auf klassischen Programmierwerkzeugen der Web-Entwicklung. In den meisten Fällen kommen [HTML5] und JavaScript zum Einsatz. Aus diesem Grund ist mit ihnen nur ein sehr eingeschränkter Zugriff auf Gerätekomponenten möglich. Ihr größter Vorteil besteht darin, dass sie unabhängig vom Betriebssystem sind. Da die Anwendungen innerhalb eines Web-Browsers laufen, können sie auf jeder Plattform gleichermaßen eingesetzt werden, ohne Anpassungen an der Codebasis vornehmen zu müssen.

2.3 Hintergrundsysteme (TR-03174, Teil 3, dieses Dokument)

Viele Anwendungen lagern die Verarbeitung und Speicherung von Daten auf ein Server-System (Hintergrundsysteme oder Backend-Services) aus. Darüber hinaus übernehmen diese Systeme oft Aufgaben zur Authentifizierung und Autorisierung von Nutzern oder andere zentrale Tätigkeiten. Dies erlaubt es, dass nicht alle Funktionalitäten der Anwendungen auf den Endgeräten umgesetzt werden müssen. Die Ausprägungen können variieren. Daher ist bei vollumfänglicher sicherheitstechnischer Betrachtung der gesamten Anwendung die Sicherheit des Hintergrundsystems essentiell. Für die Nutzung von Anwendungen, die an ein Hintergrundsystem angeschlossen sind, ist meistens eine aktive Internetverbindung zwingend erforderlich. Dabei wird für die Kommunikation zwischen Front- und Backend-Systemen häufig eine über [TLS] gesicherte Transportverbindung eingesetzt.

Der Einsatz von Hintergrundsystemen wird im wesentlichen in drei Szenarien unterschieden:

1. Der Anbieter der Anwendung verwaltet das Hintergrundsystems selbst.
2. Der Anbieter lässt das Hintergrundsystem von einem Dienstleister verwalten.
3. Das gesamte Hintergrundsystem wird bei einem Cloud-Dienstleister gehostet.

Eine Trennung zwischen Web-Anwendung und Hintergrundsystem ist aufgrund der Abhängigkeiten kaum möglich. Daher muss bei einer solchen Architektur zusätzlich die TR-03174 „Sichere Anwendungen im Finanzwesen Teil 3: Hintergrundsysteme“ [TR03174-3] beachtet werden.

2.3.1 Selbst gehostete Systeme

Bei selbst gehosteten Systemen agiert der Entwickler des Hintergrundsystems als Betreiber. Damit hat er den direkten Zugriff auf die Systeme. Die Server, auf denen das Hintergrundsystem betrieben wird, sind innerhalb der Betriebsumgebung des Herstellers untergebracht und die physische, technische und organisatorische Absicherung der Systeme erfolgt durch ihn alleine. Der Vorteil dieser Lösung besteht darin, dass der Hersteller alleine und unverzüglich auf jegliche Vorgänge reagieren kann. Da er die Systeme selber verwaltet und die Softwarekomponenten selber auswählt bzw. entwickelt, hat er am meisten Wissen über die mögliche Verwundbarkeit der Systeme. Allerdings lastet in diesem Fall auch die alleinige Verantwortung auf dem Hersteller, sodass er z.B. dauerhaft Personal abstellen muss, um Sicherheitsvorfälle zu überwachen.

Bei extern gehosteten Systemen werden die Server in einem Datacenter eines externen Dienstleisters gehostet. Die Vorteile bei dieser Lösung bestehen darin, dass der Dienstleister in der Regel mehr Erfahrung mit dem Betrieb solcher Systeme hat. Je nach Ausgestaltung übernimmt der externe Hoster auch weitergehende Aufgaben, wie z.B. die Versorgung der Betriebssysteme mit Sicherheitsupdates, Datensicherung und Backups, sowie Überwachung und Monitoring. Der Betreiber muss dem Hoster ein gewisses Maß an Vertrauen entgegenbringen, ihn aber auch steuern und überwachen. So kann er selber z.B. die Integrität der Hardware nicht überwachen. Der Hoster muss darauf achten, dass die Daten der einzelnen Kunden und Systeme voneinander separiert sind. Durch die Aufteilung der Zuständigkeiten können zeitkritische Reibungsverluste entstehen.

2.3.2 Cloud Computing

Cloud Computing beschreibt ein Modell, das bei Bedarf zeitnah und mit wenig Aufwand geteilte Computerressourcen als Dienstleistung, etwa in Form von Servern, Datenspeicher oder Anwendungen, bereitstellt. Je nach Bedarf können Ressourcen flexibel angepasst werden. Dadurch hat der Hersteller der Anwendung weniger Einfluss auf die Ausführungsumgebung als bei einem einfachen Hosting. Das BSI empfiehlt beim Einsatz von Cloud Computing für Anwendungen im Sinne der TR auf Anbieter zurückzugreifen, welche die Anforderungen aus dem „Kriterienkatalog Cloud Computing“ des BSI [KCC-C5] erfüllen. Alternativ sind Anbieter mit vergleichbaren Testaten oder Zertifikaten zulässig (vgl. [TR03174-3]).

3 Security Problem Definition

Die Security Problem Definition beschreibt Annahmen, Bedrohungen und organisatorische Sicherheitspolitiken, die für Anwendungen im Finanzwesen zur Erbringung der Sicherheitsleistung relevant sind. Diese müssen nicht abschließend sein und können nach den individuellen Anforderungen ergänzt werden.

3.1.1 Annahmen

A.Hardware	Die Hardware ist sicher. Es gibt keine unveröffentlichten Angriffe auf die Hardware.
A.UserCredentials	Der Nutzer gibt sein Passwort nicht bewusst oder freiwillig weiter.
A.PasswordReset	Der für das Gesamtsystem genutzte Dienst des Nutzers oder der Account zum Zurücksetzen des Passwortes ist nicht kompromittiert.
A.Admin	Der Administrator, der für die Wartung des Systems Zugriff auf die Server-Komponenten hat, ist kompetent und vertrauenswürdig, sodass vorsätzlich böswillige oder grob fahrlässige Handlungen auszuschließen sind.

3.1.2 Bedrohungen

T.EavesdropCom	Angreifer können die Kommunikation zwischen Hintergrundsystem und Applikation abhören und damit sensible Daten mitlesen oder die Kommunikation abfangen und durch manipulierte Pakete ersetzen. Es können sensible Daten ausgelesen und auf dem Transportweg manipuliert werden.
T.ReadAssets	Angreifer können Daten auf dem Server auslesen. Dies können entweder sensible Daten der Nutzer, oder deren Authentifizierungsinformationen sein. Außerdem ist es möglich, durch die gewonnenen Informationen eine Grundlage für weitere Angriffe wie insbesondere T.HijackBackend zu schaffen.
T.ManipulateAssets	Angreifer können Daten auf dem Server unbemerkt manipulieren. Dadurch können Nutzer getäuscht und zu ungewollten Aktionen verleitet werden. Sicherheitsmaßnahmen können umgangen werden. Außerdem ist es möglich, durch die Manipulation einiger Daten eine Grundlage für weitere Angriffe wie insbesondere T.HijackBackend zu schaffen.
T.HijackBackend	Der Angreifer bringt einen oder mehrere Dienste des Hintergrundsystems unter seine Kontrolle. Dadurch können Nutzerdaten in großem Umfang abgefangen werden.
T.SensitiveDataExport	Sensible Daten werden unverschlüsselt in Log- oder Backup-Dateien außerhalb des gesicherten Hintergrundsystems vorgehalten. Ein Angreifer kann mit reduziertem Aufwand auf diese Daten zugreifen.

3.1.3 Organisatorische Sicherheitspolitiken

OSP.Authorization	Der Hersteller entwickelt ein Autorisierungskonzept, welches sowohl den lesenden, als auch den schreibenden Zugriff auf sensible Daten steuert. Die Zugriffsberechtigungen müssen so gewählt werden, dass ausschließlich für die Erfüllung des primären bzw. rechtmäßigen Zwecks erforderliche Rechte erteilt werden. Das Autorisierungskonzept muss unabhängig von der Authentifizierung implementiert werden.
OSP.SecurityLog	Alle Logs zu sicherheitsrelevanten Ereignissen werden auf dem Hintergrundsystem gespeichert.

OSP.CriticalUpdates	Der Hersteller überprüft und überwacht die Server-Betriebssysteme sowie die genutzte Drittanbieter-Software ¹ dauerhaft auf ausnutzbare Schwachstellen und Updates. Der Hersteller muss bei bekannt werden von Schwachstellen kurzfristig ein Update einspielen und weiterhin ein hohes Patchlevel verfolgen.
OSP.ServicesIn	Von externen Diensten eingehende Daten sollen vor einer Verarbeitung im Hintergrundsystem validiert werden (z. B. XML-Schemavalidierung, Prüfung auf ungültiges Encoding, etc.). Ziel ist es, die Anwendung vor Angriffen durch bösartige Eingaben zu schützen. <i>Anwendungshinweis:</i> Wird eine potentiell schädliche Eingabe erkannt, muss sie entweder bereinigt/maskiert oder abgelehnt/verworfen werden. Das Verwerfen sollte dem Bereinigen vorgezogen werden.
OSP.ServicesOut	Das Hintergrundsystem soll sensible Daten nicht im Klartext an externe Dienste weitergeben. <i>Anwendungshinweis:</i> Sofern vorher maskierte oder bereinigte Eingaben weitergegeben werden, müssen diese so maskiert oder enkodiert werden, dass sie im Kontext der Weitergabe keine schädlichen Effekte haben.
OSP.Libraries	Im Hintergrundsystem verwendete Frameworks bzw. Libraries dürfen keine eigenständigen Verbindungen zu externen Diensten aufbauen, die nicht explizit vom Hintergrundsystem-Betreiber freigegeben wurden.
OSP.Purpose	Jegliche Datenerhebung, -verarbeitung, -speicherung und -weitergabe darf nur mit einer Zweckbindung erfolgen. Der Hersteller veröffentlicht dafür den rechtmäßigen Zweck der Anwendung und darüber hinaus welche Daten wie verarbeitet werden und wo und wie lange sie gespeichert werden.
OSP.SecurityLifeCycle	Der Hersteller realisiert einen Entwicklungszyklus, dessen Teilschritte darauf ausgelegt sind, die Sicherheit des Hintergrundsystems zu stärken. Darunter fallen Maßnahmen, mit denen bösartige Aktivitäten erkannt werden und der Betreiber angemessene Gegenmaßnahmen einleiten kann.

3.1.4 Restrisiken

Der Betrieb eines Hintergrundsystems für Anwendungen im Finanzwesen hat besonders hohe Anforderungen an die Vertraulichkeit der gespeicherten und verarbeiteten Daten. Daher weist die Technische Richtlinie auf bestehende Restrisiken hin.

Persönliche Daten, wie Informationen über den Finanzstatus, die in großer Menge auf aus dem Internet erreichbaren Servern verarbeitet bzw. gespeichert werden, ziehen erfahrungsgemäß das Interesse unterschiedlicher Angreifertypen auf sich.

Regelmäßig werden große Datensätze personenbezogener Daten in Leaks veröffentlicht, sodass davon auszugehen ist, dass es noch eine erhebliche Menge weiterer Diebstähle gibt, die nicht an die Öffentlichkeit kommen.

In der Regel werden Einbrüche, die zu solchen Leaks führen durch bekannte Schwachstellen der verwendeten Software ermöglicht. Aber auch bei einem aktuellen Software-Stand besteht das Risiko, für sogenannte 0-Day-Exploits, also Angriffe, bei denen bisher unveröffentlichte Schwachstellen zum Diebstahl von Daten ausgenutzt werden. Darüber hinaus kann sich ein Angreifer durch Verwendung geeigneter Schwachstellen in

¹ Unter einer Drittanbieter-Software soll die Zusammenfassung von Funktionalität verstanden werden, die nicht in der Hoheit des Entwicklers des Hintergrundsystems entstanden ist und die auch nicht Teil der Funktionalität der verwendeten Betriebssystemplattform ist.

den Systemen des Betreibers verankern und somit über einen längeren Zeitraum Zugriff auf sensible Daten erlangen.

Ein weiteres Restrisiko besteht bei extern gehosteten Hintergrundsystemen und insbesondere bei Cloud-Anbietern. Der jeweilige Betreiber hat i.d.R. mehrere Kunden und muss die Zugriffsberechtigungen strikt voneinander trennen. Im Rahmen einer kurzfristigen Fehlkonfiguration kann es zu ungewollten Zugriffsmöglichkeiten auf das System kommen, welche es ermöglichen können, z.B. ein vollständiges Datenbankabbild zu ziehen. Eine unzureichende Mandantentrennung kann ebenfalls durch eine unzureichende Sicherheit in dem Hintergrundsystem selbst entstehen, sofern dieses Hintergrundsystem von mehreren Kunden genutzt werden kann.

Das Schadenspotential eines Daten-Leaks wird zusätzlich erhöht, sofern die zur Verschlüsselung verwendeten Schlüssel nicht selbst geschützt werden. Darüber hinaus erhöht die Verwendung des gleichen Schlüssels für mehrere Operationen das Restrisiko, da bei Erlangen eines Schlüssels ein Zugriff auf mehrere Daten erfolgen kann.

4 Prüfaspekte für Anwendungen im Finanzwesen

Im Folgenden sind die Empfehlungen an ein Hintergrundsystem aufgeführt. Diese basieren auf technische Empfehlungen und teilweise regulatorischen Vorgaben, deren Umsetzung für die Informationssicherheit von großer Bedeutung sind. Prüfkriterium und -tiefe (Anlage B) leiten sich aus diesen Empfehlungen ab.

4.1 Anwendungszweck

Tabelle 2 Anwendungszweck

Kürzel	Empfehlungen
O.Purp_1	Das Hintergrundsystem DARF KEINE Daten erheben und verarbeiten, die nicht dem rechtmäßigen Zweck der Anwendung dienen.
O.Purp_2	Das Hintergrundsystem MUSS vor jeglicher Erfassung oder Verarbeitung personenbezogener Daten eine aktive und eindeutige Einwilligungserklärung des Nutzers einholen. Daten, deren Verarbeitung der Nutzer nicht ausdrücklich zugestimmt hat, DÜRFEN NICHT von dem Hintergrundsystem verarbeitet werden.
O.Purp_3	Der Anbieter MUSS ein Verzeichnis führen, welches erkennen lässt, welche Nutzereinzwilligungen vorliegen. Der nutzerspezifische Teil des Verzeichnisses MUSS für den Nutzer automatisiert einsehbar sein. Es MUSS eine Historie dieses Verzeichnisses angefordert werden können.
O.Purp_4	Setzt das Hintergrundsystem Drittanbieter-Software ein, SOLLEN alle verwendeten Funktionen für den rechtmäßigen Zweck des Gesamtsystems erforderlich sein. Anderweitige Funktionen SOLLEN sicher deaktiviert sein. Wird nur eine einzige oder sehr wenige Funktionen der Drittanbieter-Software benötigt, SOLL abgewogen werden, ob die Einbindung der gesamten Drittanbieter-Software im Verhältnis zur Vergrößerung der Angriffsfläche durch die verwendete Drittanbieter-Software steht.
O.Purp_5	Sofern es nicht für den vorgesehenen primären oder rechtmäßigen Zweck einer Anwendung erforderlich ist, DÜRFEN sensible Daten NICHT mit Dritten geteilt werden. Dies betrifft auch die Ablage dieser Daten in Teilen des Dateisystems, auf die auch andere Anwendungen Zugriff haben. Die Anwendung MUSS den Nutzer über die Konsequenzen einer eventuellen Weitergabe von Anwendungsdaten, die dem primären oder rechtmäßigen Zweck dienen, vollumfänglich informieren und sein Einverständnis einholen (OPT-IN).

4.2 Architektur

Tabelle 3 Architektur

Kürzel	Empfehlungen
O.Arch_1	„Security“ MUSS ein fester Bestandteil des Softwareentwicklungs- und Lebenszyklus für die gesamte Anwendung sein.
O.Arch_2	Bereits in der Designphase des Hintergrundsystems MUSS berücksichtigt werden, dass das Hintergrundsystem der Anwendung in der Produktivphase sensible Daten verarbeiten wird. Die Architektur des Hintergrundsystems MUSS dafür die sichere Erhebung, Verarbeitung, Speicherung und Löschung der sensiblen Daten in einem Datenlebenszyklus gewährleisten.
O.Arch_3	Der Lebenszyklus von kryptographischem Schlüsselmaterial MUSS einer ausgearbeiteten Richtlinie folgen, die Eigenschaften wie die Zufallszahlenquelle, detaillierte Angaben zur Aufgabentrennung von Schlüsseln, Ablauf von Schlüsselzertifikaten, Integritätssicherung durch Hash-Algorithmen etc., umfasst. Die Richtlinie SOLL auf anerkannten Standards wie [TR02102-2] und [NIST80057] basieren.

O.Arch_4	In Backups gespeicherte sensible Daten MÜSSEN gemäß dem Stand der Technik verschlüsselt sein.
O.Arch_5	Sicherheitsfunktionen MÜSSEN immer auf allen Außenschnittstellen und API-Endpunkten implementiert werden.
O.Arch_6	Nutzt das Hintergrundsystem Drittanbieter-Software (etwa für Datenbanken, Authentifizierung oder Logging), MUSS der Hersteller sicherstellen, dass nur solche Drittanbieter-Software zum Einsatz kommt, deren zu nutzende Funktionen sicher genutzt werden können und dem Nutzer Informationen über den Nutzungsumfang und die eingesetzten Sicherheitsmechanismen klar darstellt. Das Hintergrundsystem MUSS diese Funktionen sicher nutzen. Der Hersteller MUSS darüber hinaus sicherstellen, dass ungenutzte Funktionen durch Dritte nicht aktiviert werden können.
O.Arch_7	Das Hintergrundsystem MUSS alle Anfragen der Anwendung über eine vollständig dokumentierte API entgegennehmen. Es DARF KEINE nicht dokumentierten Zugriffsmöglichkeiten enthalten.
O.Arch_8	Der Hersteller SOLL dem Nutzer eine barrierearme Möglichkeit bereitstellen, um Sicherheitsprobleme zu melden. Die Kommunikation SOLL über einen verschlüsselten Kanal stattfinden.
O.Arch_9	Das Hintergrundsystem MUSS so implementiert sein, dass ungewollte Zugriffe über eventuelle Management-Schnittstellen effektiv unterbunden werden. Insbesondere bei externem Hosting (s. Kapitel 2.3.2) und Cloud-Diensten (s. Kapitel 2.3.3) MUSS sichergestellt werden, dass der Betreiber Zugriffsmöglichkeiten zwischen verschiedenen Kunden unterbindet.
O.Arch_10	Dienste, die das Hintergrundsystem zur Verfügung stellt, SOLLEN nur mit den notwendigen Rechten ausgeführt werden. Dienste, die von außen erreichbar sind, DÜRFEN NICHT mit Administrator-, System- bzw. Root-Rechten laufen.
O.Arch_11	Das Hintergrundsystem MUSS über ein zentrales Protokollierungssystem verfügen, in dem alle Log-Nachrichten der verschiedenen Dienste zusammenlaufen. Protokolle SOLLEN auf einem dedizierten System (sog. Logserver) gesammelt werden, um einem Löschen und Manipulieren auf den Quellsystemen entgegenzuwirken.

4.3 Quellcode

Tabelle 4 Quellcode

Kürzel	Empfehlungen
O.Source_1	Das Hintergrundsystem MUSS alle Eingaben vor deren Verarbeitung prüfen, um potenziell bösartige Werte vor der Verarbeitung herauszufiltern.
O.Source_2	Das Hintergrundsystem MUSS eingehende und ausgehende Daten maskieren beziehungsweise von potenziell schadhaften Zeichen bereinigen oder deren Verarbeitung ablehnen.
O.Source_3	Potenzielle Ausnahmen im Programmablauf (Exceptions) MÜSSEN abgefangen, kontrolliert behandelt und dokumentiert werden. Technische Fehlerbeschreibungen (z.B. Stack Traces) DÜRFEN dem Nutzer NICHT angezeigt werden.
O.Source_4	Bei Ausnahmen im Programmablauf (Exceptions) SOLL das Hintergrundsystem Zugriffe auf sensible Daten abbrechen und die Anwendung anweisen, diese im Speicher sicher zu löschen.
O.Source_5	Sofern das Hintergrundsystem oder Teile davon über eine manuelle Speicherverwaltung verfügen (d.h., das entsprechende Programm kann selbst exakt festlegen, wann und wo Speicher gelesen und beschrieben wird), MUSS für lesende und schreibende Zugriffe auf Speichersegmente auf sichere Funktionsalternativen (z. B. <code>sprintf_s</code> statt <code>printf</code>) zurückgegriffen werden.
O.Source_6	Alle Optionen zur Unterstützung der Entwicklung (z. B. Entwickler-URLs, Testmethoden, Überreste von Debugmechanismen etc.) MÜSSEN in der Produktiv-Version vollständig entfernt sein.

O.Source_7	Das Hintergrundsystem MUSS sicherstellen, dass alle sensiblen Daten unverzüglich nach der Erfüllung ihres Verarbeitungszwecks sicher gelöscht werden.
O.Source_8	Der Hersteller MUSS einen Deployment-Prozess für die Inbetriebnahme, Aktualisierungen und Abschaltung des Hintergrundsystems etablieren, der sicherstellt, dass zu keinem Zeitpunkt die Veröffentlichung oder das Kompromittieren sensibler Daten möglich ist.
O.Source_9	Der Hersteller SOLL automatische Tools zur Identifikation von Programmfehlern und Best-Practice Violations im Build Process verwenden. Jegliche Warnungen MÜSSEN von dem Hersteller vor dem Produktivbetrieb mitigiert werden.
O.Source_10	Für den Bau des Hintergrundsystem SOLLEN moderne Sicherheitsmechanismen, wie beispielsweise Obfuskation und Stack-Protection aktiviert werden.

4.4 Drittanbieter-Software

Tabelle 5 Drittanbieter-Software

Kürzel	Empfehlungen
O.TrdP_1	Der Anbieter MUSS eine zentrale und vollständige Liste von Abhängigkeiten durch Drittanbieter-Software führen.
O.TrdP_2	Drittanbieter-Software MUSS in der neusten oder der ihr vorhergehenden, für die Veröffentlichung vorgesehenen Version verwendet werden.
O.TrdP_3	Drittanbieter-Software MUSS durch den Hersteller regelmäßig (durch Auswertung öffentlich verfügbarer Informationen oder durch statische/dynamische Testmethoden) auf Schwachstellen überprüft werden. Überreste von Optionen zur Unterstützung der Entwicklung (vgl. O.Source_6) sind hierbei als Schwachstelle zu werten. Der Hersteller MUSS für alle öffentlich bekannten Schwachstellen analysieren, inwieweit die Schwachstelle die Sicherheit des Gesamtsystems beeinträchtigt. Software, bzw. Funktionen aus Drittanbieter-Software DÜRFEN bei bekannten Schwachstellen, die die Sicherheit des Gesamtsystems betreffen NICHT eingesetzt werden.
O.TrdP_4	Sicherheitsupdates für Drittanbieter-Software sowie Betriebssysteme MÜSSEN zeitnah eingespielt werden. Der Hersteller MUSS ein Sicherheitskonzept vorlegen, das anhand der Kritikalität ausnutzbarer Schwachstellen die geduldete Weiternutzung für das Hintergrundsystem festlegt. Nachdem die Übergangsfrist (Grace Period) abgelaufen ist, MUSS das Hintergrundsystem bis zur Behebung der Schwachstelle deaktiviert werden.
O.TrdP_5	Vor der Verwendung von Drittanbieter-Software MUSS deren Quelle auf Vertrauenswürdigkeit geprüft werden.
O.TrdP_6	Die Anwendung SOLL sensible Daten NICHT an Drittanbieter-Software weitergeben.
O.TrdP_7	Über Drittanbieter-Software eingehende Daten MÜSSEN validiert werden.
O.TrdP_8	Drittanbieter-Software die nicht mehr gewartet wird, DARF NICHT verwendet werden.
O.TrdP_9	Wenn das Hintergrundsystem externe Dienste verwendet, die nicht unter der Kontrolle des Herstellers stehen MUSS der Nutzer über die mit den Diensten geteilten Daten informiert werden. Dies gilt auch, wenn das Hintergrundsystem oder Teile davon als Cloud-Lösung realisiert sind.
O.TrdP_10	Schnittstellen zwischen Hintergrundsystemen des Herstellers und externen Diensten MÜSSEN gemäß O.Arch_5 geschützt werden.

4.5 Kryptographische Umsetzung

Tabelle 6 Kryptographische Umsetzung

Kürzel	Empfehlungen
O.Cryp_1	Beim Einsatz von Verschlüsselung in der Anwendung DÜRFEN KEINE fest einprogrammierten geheimen, bzw. privaten Schlüssel eingesetzt werden.
O.Cryp_2	Die Anwendung MUSS auf bewährte Implementierungen zur Umsetzung kryptographischer Primitive und Protokolle zurückgreifen (vgl. [TR02102-2]).
O.Cryp_3	Die Wahl kryptographischer Primitive MUSS passend zum Anwendungsfall sein und dem aktuellen Stand der Technik (siehe [TR02102-1]) entsprechen.
O.Cryp_4	Kryptographische Schlüssel DÜRFEN NICHT für mehr als genau einen Zweck eingesetzt werden. Der Hersteller des Hintergrundsystems MUSS ein Verschlüsselungskonzept vorlegen, aus dem alle verwendeten Schlüssel und deren Hierarchien hervorgehen.
O.Cryp_5	Die Stärke der kryptographischen Schlüssel MUSS dem aktuellen Stand der Technik entsprechen (siehe [TR02102-1]).
O.Cryp_6	Alle kryptographischen Schlüssel SOLLEN in einer vor Manipulation und Offenlegung geschützten Umgebung liegen.
O.Cryp_7	Alle kryptographischen Operationen SOLLEN in einer vor Manipulation und Offenlegung geschützten Umgebung stattfinden.
O.Cryp_8	Bei TLS-Verbindungen MUSS eine der in der TR02102-2 empfohlenen Cipher-Suiten verwendet werden. Verbindungen, die diese Cipher-Suiten nicht unterstützen DÜRFEN NICHT aufgebaut werden.
O.Cryp_9	Alle Zufallswerte MÜSSEN über einen starken kryptographischen Zufallszahlengenerator erzeugt werden, welcher mit ausreichend Entropie „geseedet“ wurde (vgl. [TR02102-1]).

4.6 Authentisierung und Authentifizierung

Tabelle 7 Authentisierung und Authentifizierung

Kürzel	Empfehlungen
O.Auth_1	Der Hersteller MUSS ein Konzept zur Authentisierung auf angemessenem Vertrauensniveau (vgl. [TR03107-1]), zur Autorisierung (Rollenkonzept) und zum Beenden von Sitzungen dokumentieren. Das Konzept MUSS hierbei auch Kommunikationsverbindungen innerhalb eines Hintergrundsystem-Netzwerkes berücksichtigen.
O.Auth_2	Das Hintergrundsystem MUSS für die Anbindung einer Anwendung eine geeignete Authentisierung unterstützen.
O.Auth_3	Das Hintergrundsystem SOLL Authentisierungsmechanismen und Autorisierungsfunktionen separat realisieren. Sind für den Zugriff auf das Hintergrundsystem verschiedene Rollen notwendig, MUSS eine Autorisierung bei jedem Datenzugriff separat realisiert werden.
O.Auth_4	Ist eine Zwei-Faktor-Authentifizierung gefordert, z.B. aufgrund regulatorischer Vorgaben oder dem Umgang mit besonders schützenswerten Daten, MÜSSEN die Faktoren aus den Kategorien Wissen, Besitz und Inhärenz kommen, wobei die Faktoren aus unterschiedlichen Kategorien sein MÜSSEN . Die Faktoren MÜSSEN vor unbefugtem Zugriff bzw. Verwendung geschützt werden.
O.Auth_5	Der Nutzer MUSS über ungewöhnliche Anmeldevorgänge informiert werden.
O.Auth_6	Das IT-System bzw. die IT-Anwendung SOLL nach jedem erfolglosen Authentisierungsversuch weitere Anmeldeversuche zunehmend verzögern (Time Delay). Die Gesamtdauer eines Anmeldeversuchs SOLL begrenzt werden können. Nach Überschreitung der vorgegebenen Anzahl erfolgloser Authentisierungsversuche SOLL das IT-System bzw. die IT-Anwendung die Benutzendenkennung sperren.

O.Auth_7	Die Anwendung MUSS nach einer angemessenen Zeit in der sie nicht aktiv verwendet oder unterbrochen wurde eine erneute Authentisierung fordern. Alle alten Sitzungsdaten SOLLEN ungültig und gelöscht sein. Diese Regelungen sollen auch für die Verbindung zum Hintergrundsystem gelten.
O.Auth_8	Die Authentisierungsdaten DÜRFEN NICHT ohne eine erneute Authentifizierung des Nutzers geändert werden.
O.Auth_9	Authentisierungsdaten, wie bspw. Session-IDs bzw. Authentisierungstoken, MÜSSEN als sensible Daten geschützt werden. Session-IDs MÜSSEN zufällig und mit ausreichender Entropie erzeugt werden. Wenn Session-IDs übertragen und von den Clients gespeichert werden, MÜSSEN sie ausreichend geschützt übertragen werden.
O.Auth_10	Wird eine Anwendungssitzung ordnungsgemäß beendet, MUSS die Anwendung das Hintergrundsystem darüber informieren, sodass Session-Identifizier bzw. Authentisierungstoken sicher gelöscht werden. Dies gilt sowohl für das aktive Beenden durch den Benutzer (log-out), als auch für das automatische Beenden durch die Anwendung.
O.Auth_11	Bei Änderung der Zugangsparameter MUSS der Nutzer über die zuletzt hinterlegten, gültigen Kontaktdaten über die Änderung informiert werden. Dem Nutzer SOLL über diesem Weg eine Möglichkeit geboten werden, die gemeldete Änderung zu sperren und nach entsprechender Authentifizierung neue Zugangsparameter zu setzen.
O.Auth_12	Wird der Zugang zur Anwendung, z.B. aufgrund zu vieler fehlerhafter Anmeldeversuche, temporär gesperrt, MUSS die Anwendung hierüber informieren bzw. warnen, bevor diese Sperrung dauerhaft wird. Bei einer dauerhaften Sperrung MUSS der Benutzer die Möglichkeit haben, die Nutzung wiederzuerlangen.
O.Auth_13	Für die Bewertung eines Authentisierungsvorgangs SOLLEN zusätzliche Informationen (z. B. das verwendete Endgerät, die verwendete IP-Adresse oder die Zeit des Zugriffs) mit einbezogen werden.
O.Pass_1	Bei einer Authentifizierung mittels Benutzername und Passwort SOLLEN starke Passwortrichtlinien existieren. Diese SOLLEN sich am aktuellen Stand gängiger „Best-Practices“ orientieren.
O.Pass_2	Für die Einrichtung der Authentisierung mittels Benutzername und Passwort KANN die Stärke des verwendeten Passworts dem Nutzer angezeigt werden. Informationen über die Stärke des gewählten Passworts DÜRFEN NICHT gespeichert werden.
O.Pass_3	Der Nutzer MUSS die Möglichkeit haben, sein Passwort zu ändern.
O.Pass_4	Wird die mobile oder Web-Anwendung zusammen mit einem Hintergrundsystem genutzt, SOLL das Ändern und Zurücksetzen von Passwörtern protokolliert werden. Das Hintergrundsystem SOLL den Nutzer über das Ändern und Zurücksetzen von Passwörtern informieren, dabei SOLL ein separater Kanal genutzt werden.
O.Pass_5	Werden Passwörter gespeichert, MÜSSEN diese gemäß den aktuellen Sicherheitsstandards geschützt werden.

4.7 Datensicherheit

Tabelle 8 Datensicherheit

Kürzel	Empfehlungen
O.Data_1	Sensible Daten MÜSSEN verschlüsselt gespeichert werden. Das Hintergrundsystem SOLL sensible Daten, verschlüsselt speichern, so dass sie nur von dem Nutzer selber wieder entschlüsselt werden können.
O.Data_2	Alle erhobenen sensiblen Daten DÜRFEN NICHT über die Dauer ihrer jeweiligen Verarbeitung hinaus im Hintergrundsystem gehalten werden.
O.Data_3	Das Hintergrundsystem MUSS die Grundsätze der Datensparsamkeit und Zweckbindung berücksichtigen.

O.Data_4	Das Hintergrundsystem MUSS sämtliche Metadaten mit Datenschutz-Relevanz, wie etwa Rückschlüsse auf den GPS-Koordinaten des Aufnahmeorts, eingesetzte Hardware etc., entfernen, wenn diese Daten nicht für den rechtmäßigen Zweck der Anwendung benötigt werden.
O.Data_5	Sensible Daten wie private Schlüssel DÜRFEN NICHT aus der Komponente, auf der sie erzeugt wurden, exportiert werden, außer es ist für den rechtmäßigen Zweck der Anwendung notwendig (s. Tabelle 15).
O.Data_6	Das Hintergrundsystem MUSS dem Nutzer die Möglichkeit geben, dass bei Deinstallation der Anwendung alle sensiblen Daten und anwendungsspezifischen Anmeldeinformationen vollständig vom Hintergrundsystem gelöscht bzw. unzugänglich gemacht werden. Entscheidet sich der Nutzer, die Daten im Hintergrundsystem nicht zu löschen, MUSS eine für den Zweck angemessene maximale Verweildauer definiert sein. Der Nutzer MUSS über die Verweildauer informiert werden. Nach Ablauf der maximalen Verweildauer MÜSSEN alle sensiblen Daten und anwendungsspezifischen Anmeldeinformationen vollständig gelöscht werden. Dem Nutzer MUSS die Möglichkeit gegeben werden alle Daten auch vor Ablauf der Verweildauer vollständig zu löschen oder unzugänglich zu machen.
O.Data_7	Um dem Missbrauch von sensiblen Daten nach einem Geräteverlust entgegenzuwirken, KANN die Anwendung einen Kill-Switch realisieren, d.h. ein absichtliches, sicheres Überschreiben von Nutzerdaten im Gerät auf Applikationsebene, ausgelöst durch das Hintergrundsystem. Der Hersteller MUSS die Auslösung des Kill-Switches durch den Anwender über das Hintergrundsystem durch erneute Authentifizierung vor missbräuchlicher Nutzung schützen.

4.8 Netzwerkkommunikation

Tabelle 9 Netzwerkkommunikation

Kürzel	Empfehlungen
O.Ntwk_1	Die Netzwerkkommunikation zwischen den Verbindungspartnern MUSS gegenseitig authentifiziert werden und die Kommunikation MUSS verschlüsselt erfolgen.
O.Ntwk_2	Jedes System eines Hintergrundsystem-Netzwerks MUSS über ein von einer beglaubigten Certification Authority ausgestelltes Zertifikat verfügen.
O.Ntwk_3	Jedes System MUSS , bei Kommunikationsverbindungen in denen es als Client fungiert, die gesamte Zertifikatskette prüfen.
O.Ntwk_4	Die Konfiguration der verschlüsselten Verbindungen MUSS dem aktuellen Stand der Technik entsprechen (vgl. [TR02102-2]).
O.Ntwk_5	Die Anwendung MUSS sicherheitsüberprüfte Drittanbieter-Software verwenden, um sichere Kommunikationskanäle aufzubauen. Dies schließt die im Betriebssystem mitgelieferte Bibliothek mit ein.
O.Ntwk_6	Das Hintergrundsystem MUSS die Integrität und Authentizität der Antworten der Anwendung validieren.
O.Ntwk_7	Das Hintergrundsystem MUSS für alle aufgebauten Verbindungen sowie Verbindungsversuche Log-Dateien vorhalten.
O.Ntwk_8	Ein abgebrochener Verbindungsaufbau MUSS als Sicherheitsereignis im Hintergrundsystem protokolliert werden.
O.Ntwk_9	Wenn das Hintergrundsystem aus mehreren Systemen besteht, die ein Netzwerk bilden, so MUSS dieses Netzwerk durch Firewalls an allen Schnittstellen nach außen geschützt werden.
O.Ntwk_10	Die Firewalls, die das Hintergrundsystem-Netzwerk schützen, MÜSSEN auf dem „Deny-All Ansatz“ basieren, also explizit alle nicht erlaubten Verbindungen verwerfen.

4.9 Organisatorische Sicherheit

Tabelle 10 Organisatorische Sicherheit

Kürzel	Empfehlungen
O.Org_1	Der Betreiber der Hintergrundsysteme MUSS eine Zertifizierung nach [ISO27001], auf der Basis von IT-Grundschutz [BSI27001] oder einem vergleichbaren Standard nachweisen.
O.Org_2	Ist das Hintergrundsystem komplett oder teilweise als Cloud-Lösung realisiert, SOLL der Cloud-Anbieter über den gesamten Nutzungszeitraum für die genutzten Cloud-Dienste aus der genutzten Region über ein C5 Testat vom Typ 2 oder ein vergleichbares Testat oder Zertifikat verfügen. Sofern Abweichungen oder Mängel im Testat oder Zertifikat aufgeführt werden, SOLL der Anbieter des Hintergrundsystems die daraus entstehenden Risiken analysieren und angemessen auf diese Risiken reagieren.
O.Org_3	Der Betreiber des Hintergrundsystems MUSS über ein Monitoring-System verfügen, das bei verdächtigen Operationen einen Alarm auslöst. Darüber hinaus KANN er zusätzlich ein Intrusion Detection/Prevention System einsetzen.
O.Org_4	Der Anbieter MUSS Prozesse für den Umgang mit jedem möglichen Alarmtyp des Monitoring-Systems definieren. Nicht definierte Alarmtypen MÜSSEN manuell bewertet werden.
O.Org_5	Der Anbieter MUSS ein Notfallvorsorgekonzept vorlegen, das beschreibt, wie die Versorgung bei Notfällen sichergestellt wird.

5 Anforderungen an die Prüfung

Die Prüfung mobiler Anwendungen im Finanzwesen orientiert sich an den Empfehlungen (Kapitel 4). Aus diesen werden Testcharakteristika und Prüftiefe abgeleitet, welche als Basis einer Prüfung dienen (siehe Anhang B). Unterstützend kann der Hersteller Aussagen tätigen, in denen er die betreffende Umsetzung skizziert und eine Referenz auf die jeweilige Implementierung angibt. Die untenstehende Tabelle legt dar, welche Prüfschritte mindestens für die jeweilige Prüftiefe gefordert sind.

Tabelle 11: Prüftiefen und Mindestanforderungen

Prüftiefe	Mindestanforderungen an die Prüfung
CHECK	Der Evaluator validiert (englisch „check“, analog Begriffsverwendung in der Common Criteria Evaluation Methodology) die vom Hersteller beschriebene Maßnahme im Hinblick auf ihre Wirksamkeit und räumt bestehende Zweifel (Plausibilitätsprüfung) aus, ob der Prüfaspekt und die damit verbundene Sicherheitsproblematik umfassend durch die beschriebenen Maßnahmen adressiert werden. Hierbei MUSS der Evaluator den aktuellen Stand der Technik berücksichtigen. Die Validierung KANN weitergehende Schritte, z.B. eine Quelltextanalyse, umfassen, falls der Evaluator diese für eine Einschätzung benötigt.
EXAMINE	Der Evaluator untersucht (englisch „examine“, analog zur Common Criteria Evaluation Methodology) die betreffende Testcharakteristik. Der Evaluator MUSS in seiner Prüfung über die Mindestanforderungen für „CHECK“ hinausgehen: In der Regel wird dies durch umfassende Quelltextanalyse der relevanten Implementierungsanteile und Penetrationstests geschehen. Die Unterstützung durch den Hersteller kann genutzt werden. „EXAMINE“ erfordert in jedem Fall eine eigenständige Beurteilung durch den Evaluator.

Bei Prüftiefe „CHECK“ wählt der Prüfer, wie hoch die Abdeckung der Analyse für seine Einschätzung notwendig ist. Für „EXAMINE“ muss der Prüfer erläutern, inwiefern sämtliche relevanten Codezeilen in Betracht gezogen wurden.

5.1 Protokollierung der Prüfungsergebnisse

Die Protokollierung der Testergebnisse ist so zu gestalten, dass unbeteiligte Dritte in die Lage versetzt werden, anhand der Angaben aus dem Prüfbericht die vorgenommenen Prüfschritte zu wiederholen und dabei das gleiche Ergebnis zu erzielen. Hierzu ist es neben der Beschreibung der einzelnen Prüfschritte notwendig, dass die verwendeten Prüfwerkzeuge in den verwendeten Versionen in dem Prüfbericht ersichtlich sind. Die untenstehende Tabelle definiert die zulässigen Prüfergebnisse, welche sich aus der Prüfung einer Charakteristik ergeben können. Der TR-Prüfer begründet, wie er zu einem entsprechenden Ergebnis gekommen ist.

Tabelle 12: Mögliche Prüfergebnisse

Ergebnis	Notwendige Angaben
PASS	Der Prüfer erläutert sein Verständnis, warum die Hersteller-Implementierung das geforderte Sicherheitsziel erfüllt. Der Prüfbericht führt die durchgeführten Prüfschritte sowie das Prüfergebnis aus.
INCONCLUSIVE	Der Prüfbericht spezifiziert/referenziert die fehlenden oder inkonsistenten Informationen, damit der Hersteller die Nicht-Konformität zu dem betreffenden Aspekt des Sicherheitsziel bereinigen kann.
FAIL	Die geprüfte Anwendung verfehlt das betreffende Sicherheitsziel. Der Prüfer dokumentiert, inwiefern Angriffe durch Sicherheitsmaßnahmen in der Umgebung der Anwendung (z.B. operative Maßnahmen) verhindert werden können. Der Prüfer nimmt eine Evidenz der Verletzung der Prüfcharakteristik in die Protokollierung auf. Der Prüfer nimmt das durch die Verletzung der Testcharakteristik entstehende Risiko in die Risikoabschätzung mit auf.
NOT APPLICABLE (N/A)	Die geprüfte Anwendung verfügt über keinerlei Implementierung der durch den Prüfaspekt zu schützenden Funktionalitäten. Daher kann die betreffende Testcharakteristik nicht auf die zu prüfende Anwendung angewandt werden.

5.2 Risikoanalyse und -bewertung

Die Prüfer identifizieren bestehende Restrisiken beim Einsatz der Anwendung im Finanzwesen. Mit der Aufdeckung bestehender Restrisiken wird dem Umstand Rechnung getragen, dass der Verlust von Finanzdaten zu einem Schaden für den Nutzer führt und ausreichende Schutzmaßnahmen zum Zeitpunkt der TR-Prüfung nicht identifiziert werden konnten. Die Risikobewertung muss mindestens folgende Aspekte umfassen:

- Identifikation von Risiken aus der unterlassenen oder unzureichenden Umsetzung von „SOLL“-Anforderungen in Sicherheitszielen.
- Implementierungsspezifische Risiken.
- Risiken durch Integration in der geplanten Betriebsumgebung.
- Berücksichtigung der Eignung des Monitorings sowie vorgesehene Reaktionsmöglichkeiten.

Grundlage für die Prüfung und das daraus resultierende Prüfurteil soll ein dokumentiertes Risikomanagementverfahren sein. Als allgemeine Referenz werden BSI Standard 200-3 [[BSI200-3], [ISO27005] und Anhang B der Common Criteria Evaluation Methodology [CCEM] genannt. Vergleichbare Risikomanagementverfahren sind möglich.

Die Prüfer führen eine methodische Risikoanalyse durch, die mindestens folgende Schritte umfassen muss:

1. Sicherheitsproblem vollständig aufarbeiten – Ausgangspunkt der Risikoanalyse sind die Bedrohungen, Annahmen und Sicherheitspolitiken der Anwendung (siehe Kapitel 3). Der Prüfer etabliert eine vollständige Liste aller sensiblen Daten, die in der Anwendung erfasst, erzeugt oder genutzt werden. Sensible Daten, die alleine im Hintergrundsystem verarbeitet werden, sind durch die Annahme A.Backend (siehe Kapitel 3.1.1) abgedeckt.
2. Schutzbedarf feststellen – die IT-Sicherheit betrachtet generell den Schutzbedarf hinsichtlich Vertraulichkeit, Integrität, Authentizität und Verfügbarkeit. Der Prüfer klassifiziert den jeweiligen Schutzbedarf aller verarbeiteten Daten, vgl. Anhang B in ISO 27005. Die Daten im Rahmen der TR werden anhand ihrer Kritikalität unterschieden (vgl. Tabelle 15).

3. Risikoszenarien bewerten – Der TR-Prüfer führt unter Berücksichtigung der etablierten Gegenmaßnahmen eine Bewertung von Risikoszenarien durch. Es muss dafür ein dokumentierter, ganzheitlicher Ansatz auf die sensiblen Daten der Anwendung durchgeführt werden, beispielsweise ISO 27005 , Abschnitt 8.3 und Anhänge C/D/E.

In die Bewertung durch den Prüfer geht ein, welche Schutzmaßnahmen im Produkt realisiert sind, und deren Effektivität. Ebenfalls werden Vorgaben für die sichere Nutzung berücksichtigt, sofern diese dem Nutzer ausreichend dargelegt sind. Ob das Sicherheitsproblem angemessen behandelt wird, schätzen die Prüfer anhand der Schwierigkeit ermittelter Angriffspfade ein (die Schwierigkeit eines Angriffs ersetzt dabei die in der ISO 27005 referenzierte Eintrittswahrscheinlichkeit eines Risikos).

Häufig werden für die Angriffsbewertung folgende Bewertungsprinzipien eingesetzt:

1. Zeitbasierter Ansatz – Der Prüfer schätzt den zeitlichen Aufwand eines Angreifers zur Überwindung der Sicherheitsmaßnahmen ein. Der Hersteller versichert, dass vor Ablauf dieser Zeit eine neue Produktversion mit neuem Schlüsselmaterial bereitgestellt wird (z.B. spätestens monatlich) und die Anwendung ist so beschaffen, dass Angriffe nur an der aktuellsten Produktversion ausgeführt werden können. Die Ausnutzung der Schwachstelle wird so unterbunden.
2. Reaktiver Ansatz – Hier analysiert der Prüfer die effektive Bekämpfung der Risikoszenarien mittels proaktiven Monitorings inkl. Reaktion. Beispielsweise werden Betriebsparameter erfasst und der Zugriff auf sensible Daten abgewehrt, sofern diese auf absichtliche Modifikationen hindeuten. Extern vom Hersteller selbst-realisierte Schutzmechanismen müssen mitbetrachtet werden.

Der Prüfer muss aufgrund der ermittelten Restrisiken ein Urteil abgeben, inwiefern das von der TR adressierte Sicherheitsproblem adäquat erfüllt wird. Neben der Kompromittierung und dem Verlust von Daten spielt bei Anwendungen im Finanzwesen natürlich auch der unmittelbar mögliche finanzielle Schaden bei der Risikobewertung eine wichtige Rolle, die bei der Risikobewertung zu berücksichtigen ist.

Tabelle 13: Anforderung anhand der Daten-Kritikalität

Kritikalität	Beschreibung	Anforderung
Sehr hoch	Eine Verletzung des Schutzbedarfs führt zu einem nicht zu beziffernden oder potenziell schwerwiegenden Schaden für den Dateninhaber.	Die realisierten Maßnahmen werden als wirksam erachtet, sämtliche Risikoszenarien ohne Restrisiken auszuräumen.
Hoch	Eine Verletzung des Schutzbedarfs führt zu einem hohen oder mittleren Schaden für den Dateninhaber.	Die realisierten Maßnahmen reduzieren die Risikoszenarien erheblich. Der Prüfer muss die Durchführung verbleibender Angriffe bewerten und deren Auswirkungen dokumentieren. Im Einzelfall ist das Restrisiko darzustellen und kann Auflagen in der Nutzung der Zertifizierung verursachen.
Normal	Es kann höchstens ein geringer Schaden eintreten.	Die realisierten Maßnahmen reduzieren die Risikoszenarien. Der Prüfer muss die Durchführung verbleibender Angriffe bewerten und Restrisiken offenlegen.

Anhang A: Schutzbedarf sensibler Datenelemente

Abhängig von der realisierten Anwendung und der Kritikalität der jeweils verarbeiteten Datenelemente kann ein unterschiedlicher Schutzbedarf notwendig sein. Personenbezogene Daten unterliegen dem Datenschutz und dürfen nur bei Zweckbindung und nach Einverständnis verarbeitet werden. Die Sensibilität verarbeiteter Datenelemente wird in der folgenden Tabelle bestimmt.

Tabelle 14: Schutzbedarf sensibler Datenelemente

Information	Sensibel	Übertragung an Hintergrund system erlaubt	Ablage außerhalb sicherer Umgebung erlaubt	Bemerkungen
Anwendungsdaten	Ja	Ja	Ja	-
Eingabedaten (von extern, dritter Partei, einer Drittanbieter-Software, über Tastatur oder von Gerätesensoren)	Nein, falls nicht in anderer Kategorie speziell erfasst	Ja	Ja	Vorbehandlung, u.a. Größenprüfung, Escaping-Sequenzen (je nach Weiterverarbeitung)
Zugangsdaten	Ja	Ja	Ja	z.B. salted hashing. Zulässig ist Drittanbieter-Software für Authentifizierung.
Kryptographische Schlüssel der Anwendung	Ja	Nein	Nein ²	Zulässig ist die Nutzung in Drittanbieter-Software zur Kryptographie und Session-Handling.
Aggregierte Anwendungsdaten	Ja	Ja	Ja	
Biometrische Daten	Ja	Nein	Nein ³	Biometrische Daten sind der Anwendung nicht zugänglich, außer einem Referenzmerkmal (z.B. User 1).

² Ausgenommen sind Public Keys oder kryptografische Schlüssel von Drittanbietersoftware, sofern diese nicht der Kontrolle des Anwendungs-Entwicklers unterliegen und mobile Endgeräte, die nicht über eine sichere Umgebung (z. B. embedded Secure Element/Secure Enclave/Trusted Execution Environment) verfügen.

³ Automatisch erfüllt, wenn das Betriebssystem der Anwendung diese Daten nicht zur Verfügung stellt, andernfalls müssen die Daten als sensible Daten von der Anwendung geschützt werden

Anhang B: Prüftabellen

Maßgeblich für die Überprüfung des Hintergrundsystems sind die Anforderungen aus Kapitel 4. Diese werden um

- die Prüfaspekte
- die Prüftiefe sowie
- weiterführende Informationen bzw. Verweise auf externe Informationen

ergänzt.

Die Prüfaspekte geben das Vorgehen des Prüfers („Evaluator“) vor. Dies ist als Rahmen bzw. Mindestanforderung zu verstehen, da der Prüfer, wie in Kapitel 5 beschrieben, ein ggf. vorhandenes (Rest-) Risiko zu identifizieren und zu bewerten hat, um insgesamt zu einem nachvollziehbaren Prüfungsergebnis zu gelangen.

Die Prüftiefe wird in Kapitel 5.1 beschrieben.

Die weiterführenden Hinweise beinhalten, wenn vorhanden, Verweise auf korrespondierende Vorgaben aus sonstigen technischen und regulatorischen Texten. Diese sollten dem Prüfer bereits bekannt sein und sind bei der Bewertung zu berücksichtigen.

Anhang B kann als Vorlage zur Dokumentation und Protokollierung genutzt werden. Hierzu stehen die letzten zwei Spalten für die Anmerkungen des Prüfers (siehe Kapitel 5.2) sowie das Prüfergebnis (siehe Tabelle 14) zur Verfügung.

Abkürzungsverzeichnis

Tabelle 15: Abkürzungsverzeichnis

API	Application Programming Interface (Anwendungs-/Programmierschnittstelle)
App	Applikation
A.*	Assumption (Annahme)
BSI	Bundesamt für Sicherheit in der Informationstechnik
GPS	Global Positioning System
HTML	Hypertext Markup Language
HTTP	Hypertext Transfer Protocol
HTTPS	Hypertext Transfer Protocol Secure
IoT	Internet of Things
IPC	Interprozess Kommunikation
O.*	Objective (Prüfaspekt)
OSP.*	Organizational Security Policies (Organisatorische Sicherheitspolitiken)
SDK	Software Development Kit
SGB V	Sozialgesetzbuch (SGB) Fünftes Buch (V)
SMS	Short Message Service
SPD	Security Problem Definition
SSID	Service Set Identifier
T.*	Threat (Bedrohung)
TR	Technische Richtlinie
TLS	Transport Layer Security
URL	Uniform Resource Locator

WiFi	Wireless Fidelity
WLAN	Wireless Local Area Network
XML	Extensible Markup Language

Literaturverzeichnis

[AIS20]

Bundesamt für Sicherheit in der Informationstechnik, „AIS 20: Funktionalitätsklassen und Evaluationsmethodologie für deterministische Zufallszahlengeneratoren“, 15.05.2013, verfügbar unter https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Zertifizierung/Interpretationen/AIS_20_pdf.pdf?__blob=publicationFile&v=1

[BSI200-3]

Bundesamt für Sicherheit in der Informationstechnik, „BSI-Standard 200-3 Risikoanalyse auf der Basis von IT-Grundschutz“, Version 1.0, verfügbar unter https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Grundschutz/BSI_Standards/standard_200_3.pdf?__blob=publicationFile&v=2

[BSI27001]

Bundesamt für Sicherheit in der Informationstechnik, „ISO 27001 Zertifizierung auf Basis von IT-Grundschutz“, verfügbar unter https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/Zertifizierung-und-Anerkennung/Zertifizierung-von-Managementsystemen/ISO-27001-Basis-IT-Grundschutz/iso-27001-basis-it-grundschutz_node.html;jsessionid=2B1D3D293ED1490742AC0E7C1DF454BE.internet482

[CEM]

Common Methodology for Information Technology Security Evaluation – Evaluation methodology, April 2017, Version 3.1, Revision 5, verfügbar unter <https://www.commoncriteriaportal.org/files/ccfiles/CEMV3.1R5.pdf>

[ISi-LANA]

Bundesamt für Sicherheit in der Informationstechnik, „Sichere Anbindung von lokalen Netzen an das Internet“, verfügbar unter https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Internetsicherheit/isi_lana_studie_pdf.pdf?__blob=publicationFile&v=1

[ISi-Server]

Bundesamt für Sicherheit in der Informationstechnik, „Absicherung eines Servers“, verfügbar unter https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Internetsicherheit/isi-server_pdf.pdf?__blob=publicationFile&v=1

[ISO27001]

ISO/IEC 27001:2022, Information technology – Security techniques – Information security management systems – Requirements

[ISO27005]

BS ISO/IEC 27005:2022, Information technology - Security techniques – Information security risk management

[KCC-C5]

Bundesamt für Sicherheit in der Informationstechnik, „Kriterienkatalog Cloud Computing“, Version 2026, verfügbar unter <https://www.bsi.bund.de/dok/7685384>

[NIST80057]

National Institute of Standards and Technology, „Recommendation for Key Management“, Revision 5, verfügbar unter <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-57pt1r5.pdf>

[TR02102-1]

Bundesamt für Sicherheit in der Informationstechnik, „Kryptographische Verfahren: Empfehlungen und Schlüssellängen“, Version 2021-01, verfügbar unter https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Publikationen/TechnischeRichtlinien/TR02102/BSI-TR-02102.pdf?__blob=publicationFile&v=10

[TR02102-2]

Bundesamt für Sicherheit in der Informationstechnik, „Kryptographische Verfahren: Empfehlungen und Schlüssellängen Teil 2 – Verwendung von Transport Layer Security (TLS)“, Version 2021-01, verfügbar unter https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Publikationen/TechnischeRichtlinien/TR02102/BSI-TR-02102-2.pdf?__blob=publicationFile&v=2

[TR03107-1]

Bundesamt für Sicherheit in der Informationstechnik, „Elektronische Identitäten und Vertrauensdienste im E-Government Teil 1“, Version 1.1.1, verfügbar unter <https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Publikationen/TechnischeRichtlinien/TR03107/TR-03107-1.html>

[TR03174-1]

Bundesamt für Sicherheit in der Informationstechnik, „Anforderungen an Anwendungen im Finanzwesen Teil 1: Mobile Anwendungen“, Version 2.0, verfügbar unter <https://www.bsi.bund.de/dok/TR-03161-1>

[TR03174-2]

Bundesamt für Sicherheit in der Informationstechnik, „Anforderungen an Anwendungen im Finanzwesen Teil 2: Web-Anwendungen“, Version 1.0, verfügbar unter <https://www.bsi.bund.de/dok/TR-03161-2>